Remote Work and Endpoint Security Policy

Policy ID: POL-EUC-007 | Version 1.0 | Classification: Internal

Policy Owner	CISO / Chief Information Officer	**Effective Date**	12 September 2026
Review Cycle	At least annually and upon material legal, threat, technology, or business change	**Approval Authority**	Executive Risk / Information Security Governance Committee
Applies To	Enterprise workforce, controlled entities, and in-scope suppliers	**Control Status**	Mandatory unless formally excepted

Mandatory language: "MUST" and "MUST NOT" indicate mandatory requirements. "SHOULD" indicates an expected control that may be varied only when a risk-based alternative is documented. "Strictly Prohibited" identifies conduct that is not permitted absent an explicit, legally valid emergency or exception pathway.

1. Objective

This policy defines mandatory controls for remote work, laptops, desktops, mobile devices, virtual desktops, home networks, removable media, and remote access to enterprise services. Its objective is to maintain enterprise security regardless of employee location and to prevent credential theft, data loss, malware, unauthorized local access, and unmanaged-device exposure.

2. Scope

This policy applies to employees, contractors, temporary workers, and suppliers using enterprise-managed or approved devices to access enterprise systems from offices, homes, hotels, client sites, public spaces, or while traveling. It applies to laptops, desktops, smartphones, tablets, virtual desktops, privileged workstations, and approved bring-your-own-device scenarios.

3. Governance, Accountability, and Roles

IT Endpoint Engineering. Provides managed builds, MDM/EDR, patching, encryption, inventory, and remote support.

Security Operations. Monitors endpoint telemetry and may isolate devices presenting material risk.

Users. Protect devices and credentials, follow physical-security requirements, report loss or suspicious activity, and may not disable controls.

Managers. Ensure remote work arrangements use approved devices and access methods.

4. Policy Rules and Mandatory Guidelines

- Enterprise work MUST be performed on enterprise-managed devices unless an approved BYOD/VDI exception applies. Personal computers MUST NOT store Restricted or Confidential enterprise data.
- Full-disk encryption is Mandatory for laptops and mobile devices that store enterprise data. Users MUST NOT disable encryption, EDR, MDM, host firewall, secure boot, or other centrally managed controls.
- Devices MUST automatically lock after the enterprise-defined inactivity interval and require strong authentication to unlock. Shared household accounts or shared device credentials are prohibited.
- Phishing-resistant MFA is required for privileged and high-risk remote access where supported. Password-only remote access to enterprise networks is prohibited.
- Enterprise data MUST NOT be synchronized to personal cloud drives, personal email, consumer messaging services, or unapproved note-taking/AI applications.
- Public or shared computers, hotel business-center devices, cybercafe systems, kiosk devices, and borrowed devices MUST NOT be used to access enterprise systems except public information.

- Users MUST physically secure devices in public places and while traveling. Devices MUST NOT be left unattended in unlocked vehicles or checked baggage when avoidable.
- Lost, stolen, or suspected-compromised devices MUST be reported immediately. Users MUST NOT delay reporting while independently searching for a device if enterprise data or credentials may be exposed.
- Removable storage is disabled or restricted by default. Use of USB storage for sensitive data requires approved encrypted media and documented business need.
- Local administrator privileges are prohibited for standard users except through approved privilege-management mechanisms with time-bounded elevation.
- Remote workers MUST NOT connect enterprise-managed endpoints to untrusted peripherals that require unknown drivers or firmware, including found USB devices or promotional media.
- Screens displaying confidential information MUST be positioned to reduce casual observation in public/shared areas. Printing sensitive material at home requires explicit need and secure disposal.

5. Technical and Coding Constraints

- Managed endpoints MUST run supported operating-system versions, enterprise EDR/anti-malware, host firewall, disk encryption, patch management, device inventory, and configuration enforcement.
- Critical security patches for actively exploited vulnerabilities MAY be deployed on an emergency basis outside normal maintenance windows. Users MUST NOT intentionally defer mandatory updates beyond configured limits.
- Remote administrative protocols such as RDP and SSH MUST NOT be directly exposed from endpoints to the public Internet. Administrative access must traverse approved enterprise access controls.
- DNS, secure web gateway, VPN/ZTNA, or equivalent protections MUST be used according to enterprise configuration. Users MUST NOT install consumer VPNs that bypass enterprise monitoring on managed devices.
- Endpoint browsers MUST use enterprise-managed security settings for work profiles where applicable. Installation of unapproved extensions with broad page or credential access is prohibited.
- Developer endpoints that handle source code or signing/build credentials MUST use approved secret storage. Plaintext .env files containing production credentials and private keys stored in user profile folders are prohibited unless protected by approved local controls and only for non-production use.
- Mobile devices accessing enterprise email or data MUST be enrolled in MDM/MAM or use approved containerized application controls. Rooted or jailbroken devices are prohibited.
- Local backups of enterprise data to unmanaged external disks are prohibited. Enterprise data must use approved managed synchronization, repository, or backup services.

6. Operational Control Requirements

- Security Operations MAY remotely isolate a device, revoke sessions, force credential reset, or initiate remote wipe for enterprise-managed data when compromise, theft, or severe policy violation is suspected.
- Endpoint compliance status SHOULD be used as a condition for access to sensitive services. Non-compliant devices may be denied access until remediated.
- Privileged administrators SHOULD use hardened privileged-access workstations or isolated administrative environments for high-impact actions.

7. Monitoring, Assurance, and Records

Compliance with this policy MUST be demonstrable. Evidence is part of the control, not an optional administrative artifact. Records MUST be retained according to the enterprise records-retention schedule, legal holds, applicable regulation, and contractual requirements.

Minimum expected records:

- Endpoint inventory

- MDM/EDR compliance telemetry
- Patch records
- Device loss/theft reports
- BYOD exceptions
- Remote-wipe/isolation evidence
- Privileged workstation assignments

Security, Internal Audit, Privacy, Legal, Compliance, and authorized risk functions MAY request evidence and perform sampling or technical validation. System owners MUST provide accurate evidence and MUST NOT suppress, alter, or fabricate control records.

8. Enforcement and Violation Consequences

Violations may result in device quarantine, removal of local administrator rights, revocation of remote access, mandatory retraining, disciplinary action, or supplier remedies. Deliberate disabling of EDR/MDM, concealment of device loss, credential sharing, or intentional exfiltration is serious misconduct.

Where a violation creates active risk, protective action may occur before disciplinary or contractual review is complete. Enforcement decisions will consider intent, recurrence, severity, impact, legal duties, and whether the individual promptly reported the issue and cooperated with remediation.

9. Exceptions and Risk Acceptance

Endpoint exceptions require the device/user, business need, data classification, missing control, compensating control, Security/IT owner, and expiration. BYOD approval never permits local storage of data classes excluded by the mobile/BYOD standard.

An exception MUST NOT be interpreted as permanent policy change. The control owner may require additional monitoring, narrower scope, remediation milestones, or earlier review. Expired exceptions automatically cease to authorize the deviation.

10. Standards and Regulatory Alignment

This policy is designed to support the enterprise ISMS and cybersecurity risk program. Mappings are implementation aids; they do not replace a formal applicability analysis, legal advice, or the authoritative standards and regulations.

Framework	Policy alignment
ISO/IEC 27001:2022	Supports endpoint-device security, remote working, access control, malware protection, configuration, patching, information transfer, and incident reporting.
NIST CSF 2.0	PR.AA access; PR.PS platform security; PR.DS data security; DE.CM endpoint monitoring; RS.MA incident management; RC restoration.
GDPR	Article 32 applies where endpoints access personal data; loss/theft can trigger personal-data breach assessment under Articles 33 and 34.

Authoritative reference set

- ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements. This policy supports the ISMS risk-management model and applicable Annex A controls without reproducing proprietary standard text.
- NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (2024). Control outcomes are organized across GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER as applicable.
- Regulation (EU) 2016/679 (General Data Protection Regulation, GDPR), including the principles of Article 5 and, where applicable, Articles 6, 25, 28, 30, 32, 33, 34, 35, and Chapter V on international transfers.

11. Review, Maintenance, and Approval

The policy owner MUST review this document at least annually and whenever a material incident, audit finding, law/regulation, technology change, threat development, merger/acquisition, or operating-model change may affect its adequacy. Proposed changes MUST be version-controlled and approved through the enterprise policy governance process. Local procedures may impose stricter requirements but MUST NOT weaken this policy without an approved exception.

End of controlled document.